

Reporte Ejecutivo de Riesgos

Clinica privada – Registro inicial de riesgos en SimpleRisk

Dirigido al Directorio | Septiembre 2026 | Escenario ficticio (TP Seguridad de Sistemas)

Resumen ejecutivo

Se realizó un análisis de riesgos de seguridad de la información porque no se contemplaban formalmente los escenarios en los que los sistemas de la clínica podrían verse comprometidos. Se identificaron 7 riesgos específicos del contexto de la organización. El más urgente es R07: el personal utiliza contraseñas débiles o reutilizadas, fácilmente vulnerables tanto por un atacante externo como por alguien dentro de la organización, con riesgo de acceso indebido a información sensible. Ya se encuentran en planificación 3 acciones concretas para reducir los riesgos de mayor nivel.



Decision requerida

Autorizar el inicio de los 3 planes de acción ya definidos y priorizar la implementación de una política de contraseñas obligatoria junto con autenticación multifactor (MFA), por tratarse del riesgo de mayor nivel (R07, Crítico).

Top 5 riesgos por nivel

ID	Riesgo	Prob. × Imp.	Nivel
R07	Contraseñas débiles o reutilizadas	4 × 4 = 16	Crítico
R01	Acceso indebido a historias clínicas por personal sin necesidad de uso	3 × 4 = 12	Alto
R06	Equipamiento médico (IoT) como puerta de entrada a la red	3 × 4 = 12	Alto
R03	Phishing dirigido al personal administrativo y médico	2 × 4 = 8	Medio
R02	Filtración de datos de facturación y obras sociales	2 × 4 = 8	Medio

Clasificación según la matriz de la cátedra: crítico 16–25, alto 10–15, medio 5–9, bajo 1–4.

Estado de los planes de acción

Los 3 planes se encuentran en estado **Mitigation Planned**, con 0% de avance. El riesgo residual solo podrá reconocerse una vez implementados y verificados los controles propuestos.

Plan	Riesgo	Responsable	Vencimiento	Presupuesto
Control de acceso por rol / especialidad	R01	Jefe de Sistemas	05/10/2026	Bajo
Segmentación de red para equipos IoT	R06	Jefe de Sistemas	20/10/2026	Medio
Política de contraseñas obligatoria + MFA	R07	Jefe de Sistemas / Admin. IT	28/09/2026	Medio

Nota: R02 y R03 (nivel Medio) aún no cuentan con un plan formal asociado.

Seguimiento sugerido

Solicitar una actualización mensual del porcentaje de avance de cada plan al responsable asignado, y evaluar en 60 días si corresponde definir planes formales adicionales para R02 y R03.

Recomendaciones prioritarias

1. **Implementar cuanto antes una política de contraseñas obligatoria y MFA.** Es el riesgo de mayor nivel (R07, Crítico) y hoy no cuenta con ningún control.
2. **Ejecutar y dar seguimiento a los 3 planes ya definidos.** Control de acceso por rol, segmentación de red para equipos médicos conectados, y política de contraseñas. Medir avance mensualmente.
3. **Capacitar al personal en detección de correos fraudulentos (phishing).** Hoy no existe ningún entrenamiento al respecto, y es la puerta de entrada más común para el robo de credenciales.
4. **Revisar periódicamente los permisos de acceso a facturación y obras sociales.** Para mantener vigente la separación de funciones ya implementada entre Analista y Auditor.
5. **Presupuestar una copia de respaldo externa (fuera del sitio).** Para no depender de un único punto de falla si el servidor principal sufre un incidente grave.

Documento elaborado en el marco del Trabajo Práctico de Seguridad de Sistemas (UCH). Todos los datos personales y organizacionales utilizados son ficticios.